

Appunti — Modulo D13: Il Pacchetto Digitale Europeo (DSA, DMA, Data Act)

Corso: Diritto dell'Informatica T **Fonte:** Appunti grezzi Lorenzo + lezione_moduloD13_pacchetto_digitale.m
Data elaborazione: 2026-06-04

Quadro d'insieme

I tre regolamenti rispondono a tre domande distinte e non si sovrappongono:

Regolamento	Domanda	Parola chiave
DSA	Cosa può stare online?	Intermediari, contenuti, responsabilità
DMA	Come si compete nei mercati digitali?	Gatekeeper, mercati, concorrenza
Data Act	Chi controlla i dati generati dai dispositivi?	IoT, portabilità, accesso

Ottima comprensione di partenza: la tripletta DSA/DMA/Data Act come tre domande distinte è il frame concettuale corretto. Lo dimostri anche nel riepilogo finale.

Tutti e tre: applicazione **extraterritoriale** (valida per chi opera nell'UE indipendentemente dalla sede), coordinamento con il GDPR, Commissione europea con ampi poteri di vigilanza. [fonte: PDF]

PARTE I — Digital Services Act (DSA)

Obiettivi principali: [fonte: PDF] - Garantire un ambiente online sicuro, prevedibile e affidabile - Proteggere i diritti fondamentali degli utenti (libertà di espressione, privacy, non discriminazione) - Contrastare la diffusione di contenuti illegali, disinformazione e manipolazione online - Rafforzare la responsabilità e trasparenza dei servizi intermediari - Promuovere innovazione e crescita del mercato digitale UE

Principio cardine: «ciò che è illegale offline è illegale online» [fonte: PDF]

Vigilanza: - **DSC nazionale** (Coordinatore dei Servizi Digitali): vigila su tutti gli intermediari — in Italia: AGCOM - **Commissione europea:** vigilanza esclusiva sulle VLOP e VLOSE - **Comitato europeo per i servizi digitali:** coordinamento tra DSC

Cosa sono VLOP, VLOSE, DSC, AGCOM?

- **VLOP** = Very Large Online Platform. Piattaforme online con 45 milioni di utenti attivi mensili nell'UE. Esempi: Facebook, YouTube, TikTok, Amazon Store. Hanno gli obblighi massimi del DSA.
- **VLOSE** = Very Large Online Search Engine. Motori di ricerca con 45 milioni di utenti attivi mensili nell'UE. Esempi: Google Search, Bing. Stessa soglia delle VLOP, ma categoria separata perché sono motori di ricerca, non piattaforme.

- **DSC** = Coordinatore dei Servizi Digitali (Digital Services Coordinator). L'autorità nazionale designata da ogni Stato membro per vigilare su tutti gli intermediari nel proprio paese.
- **AGCOM** = Autorità per le Garanzie nelle Comunicazioni. È il DSC italiano — riceve le notifiche, gestisce le controversie, coordina con la Commissione europea.

Schema: la Commissione europea controlla le VLOP e VLOSE (le più grandi); ogni DSC nazionale controlla tutti gli altri intermediari nel proprio territorio. In Italia il DSC è AGCOM.

Ambito di applicazione — i 6 livelli [fonte: PDF]

Si applica ai servizi che agiscono come intermediari tra utenti e contenuti/beni/servizi, se offerti a destinatari nell'UE (indipendentemente dalla sede del fornitore).

Categoria	Esempi	Obblighi
Mere conduit	ISP, provider di accesso internet, registri di domini	Minimi
Caching	Proxy, CDN	Minimi
Hosting	Cloud, web hosting, server dedicati	Obblighi aggiuntivi
Piattaforme online	Marketplace, social network, app store	Obblighi aggiuntivi
VLOP (> 45 mln utenti UE)	Facebook, YouTube, TikTok, Amazon Store	Obblighi massimi
VLOSE (< 45 mln utenti UE)	Google Search, Bing	Obblighi massimi

Mere conduit e caching: cosa sono esattamente?

Mere conduit (“semplice condotto”) = l'intermediario trasporta dati senza intervenire sul contenuto. Non avvia la trasmissione, non sceglie il destinatario, non modifica le informazioni. Esempio concreto: il tuo ISP (Tim, Vodafone) trasporta i tuoi dati verso qualsiasi server tu voglia raggiungere — non sa cosa trasmette, non lo modifica, non può filtrarlo senza un ordine specifico. Un registro di domini (come Aruba o GoDaddy) registra i nomi di dominio ma non controlla i contenuti dei siti a cui puntano.

Caching = l'intermediario conserva temporaneamente una copia di contenuti per migliorare le prestazioni. Esempio concreto: una CDN (Content Delivery Network) come Cloudflare memorizza nella cache le pagine di un sito web e le serve agli utenti geograficamente vicini, più velocemente del server originale. Non decide quali contenuti mettere in cache (lo fa automaticamente), ma deve rimuovere i contenuti illegali appena ne viene a conoscenza.

La differenza rispetto all'hosting: il caching è temporaneo e automatico; l'hosting è permanente e su richiesta del cliente.

Nota: esenzioni per microimprese e piccole imprese (< 50 dipendenti, < 10 mln € fatturato) — obblighi ridotti. [fonte: PDF]

Esenzione di responsabilità (safe harbour) [fonte: PDF]

Il DSA mantiene il principio di esenzione dalla responsabilità per i contenuti degli utenti, già previsto dalla Direttiva e-commerce, a condizione che l'intermediario:

- **Mere conduit** (art. 4): non avvii, non selezioni il destinatario, non modifichi le informazioni trasmesse
- **Caching** (art. 5): agisca tempestivamente per rimuovere o disabilitare l'accesso ai contenuti illegali appena ne venga a conoscenza
- **Hosting** (art. 6): agisca prontamente dopo aver ricevuto una segnalazione e non abbia conoscenza effettiva dell'illecito

Il principio del «buon samaritano» — come funziona e perché non si perde l'esenzione

Il problema logico: immagina di essere YouTube. Sai che sulla tua piattaforma ci sono video illegali. Se inizi a cercarli spontaneamente e ne trovi, potresti «acquisire conoscenza effettiva» dell'illecito — e perdere l'esenzione di responsabilità per hosting (che richiede l'assenza di tale conoscenza). Avresti quindi un incentivo paradossale a **non cercare** contenuti illegali: cercarli ti espone a responsabilità.

La soluzione del DSA: il principio del «buon samaritano» (art. 7) dice esplicitamente che le indagini volontarie condotte **in buona fede** per rilevare contenuti illegali **non fanno perdere l'esenzione**. [fonte: PDF]

Perché non si perde l'esenzione: la legge distingue tra (a) conoscenza acquisita attraverso indagine volontaria in buona fede e (b) conoscenza derivante da notifica esterna o da manifesta evidenza. Solo il tipo (b), se ignorato, può far scattare la responsabilità. La ricerca attiva in buona fede non conta come «conoscenza effettiva» ai fini del safe harbour.

Risultato pratico: YouTube può usare sistemi automatizzati per rilevare violazioni del copyright, algoritmi per identificare contenuti CSAM, revisori umani per moderare — senza rischiare di perdere l'esenzione per il solo fatto di fare queste ricerche.

Senza il principio del buon samaritano → nessuno cerca contenuti illegali spontaneamente (troppo rischioso). Con il principio → chi cerca in buona fede è protetto. [fonte: PDF]

Nessun obbligo generale di sorveglianza (art. 8): vietato imporre agli intermediari di monitorare in modo generalizzato i contenuti. [fonte: PDF]

Obblighi comuni a tutti gli intermediari [fonte: PDF]

- **Punto di contatto unico:** identificare un referente per le comunicazioni con le autorità e con gli utenti
- **Rappresentante legale nell'UE:** per i fornitori stabiliti fuori dall'UE
- **Relazione annuale sulla trasparenza:** pubblicare ogni anno una relazione sull'attività di moderazione dei contenuti
- **Ordini delle autorità:** ottemperare agli ordini di rimozione di contenuti illegali o di accesso alle informazioni degli Stati membri

Obblighi aggiuntivi per i servizi di hosting [fonte: PDF]

Tipo Azure, AWS etc.? Sì, esattamente: AWS (Amazon Web Services), Azure (Microsoft), Google Cloud, ma anche servizi più semplici come Aruba Hosting, OVHcloud, web hosting condiviso. L'hosting conserva stabilmente contenuti per conto dei clienti — è diverso dal caching (temporaneo) e dal mere conduit (solo transito). Per questo ha obblighi aggiuntivi: deve permettere segnalazioni e agire su di esse.

- **Meccanismo di segnalazione (notice & action):** consentire a chiunque di segnalare contenuti illegali e agire prontamente
- **Notifica all'utente** della decisione di rimozione e possibilità di ricorso interno

Obblighi per le piattaforme online [fonte: PDF]

Differenze tra hosting e piattaforme online?

L'hosting fornisce **infrastruttura** — spazio su un server. Il cliente carica quello che vuole; nessun altro utente interagisce direttamente con i contenuti attraverso la piattaforma.

Le piattaforme online permettono **interazione tra utenti** — il servizio connette fornitori di contenuti/beni/servizi con altri utenti. Esempi: Amazon Marketplace (venditori e compratori), Facebook (utenti tra loro), App Store (sviluppatori e utenti finali).

La piattaforma non si limita a stoccare dati: gestisce interazioni, algoritmi di raccomandazione, sistemi di recensione, meccanismi di pagamento. Per questo ha obblighi aggiuntivi rispetto all'hosting puro.

- **Segnalatori attendibili** (art. 22): priorità di trattamento per segnalazioni da soggetti certificati (ONG, autorità pubbliche, associazioni di categoria)
- **Misure anti-abuso** (art. 23): sospensione di segnalatori o destinatari che abusano sistematicamente del sistema
- **Trasparenza della pubblicità online** (art. 26): indicare chiaramente che si tratta di un annuncio, per conto di chi e perché viene mostrato
- **Divieto di pubblicità targetizzata basata su categorie speciali di dati** (es. origine etnica, salute, orientamento sessuale)
- **Divieto di pubblicità targetizzata rivolta a minori**
- **Sistemi di raccomandazione** (art. 27): spiegare i criteri principali, offrire almeno un'opzione non basata sulla profilazione

Tipo i correlati di YouTube o le raccomandazioni ADV?

Sì, i «correlati di YouTube» (video suggeriti) sono esattamente un sistema di raccomandazione — qualsiasi algoritmo che decide quale contenuto mostrarti in base al tuo comportamento passato.

Ma le raccomandazioni ADV (pubblicità) sono un discorso separato: la pubblicità ha le sue regole di trasparenza (art. 26). I sistemi di raccomandazione (art. 27) riguardano i **contenuti organici** — cosa ti mostra il feed, quali video appaiono come correlati, quali prodotti suggerisce Amazon dopo un acquisto.

L'obbligo chiave: ogni piattaforma deve offrire **almeno un'opzione di raccomandazione non basata sulla profilazione** — un modo per vedere contenuti senza che

l'algoritmo usi la tua cronologia. Su YouTube sarebbe «ordina per data di pubblicazione» invece del feed personalizzato. [fonte: PDF]

- **Risoluzione extragiudiziale delle controversie** (art. 21): accesso a organismi certificati di risoluzione alternativa

Divieto di dark pattern — art. 25 [fonte: PDF]

I fornitori di piattaforme online NON possono progettare interfacce che ingannino o manipolino i destinatari, o che compromettano la capacità di prendere decisioni libere e informate.

Esempi vietati: pulsanti di dissenso nascosti, confirm shaming, preimpostazioni a favore del fornitore, urgenza fittizia.

Connessione con D12 (AI Act): il divieto di dark pattern del DSA si sovrappone parzialmente al divieto di tecniche manipolative (pratica 1, rischio inaccettabile). La differenza: l'AI Act vieta le tecniche subliminali/manipolative realizzate tramite sistemi AI; il DSA vieta i dark pattern nell'interfaccia indipendentemente dall'uso dell'IA. [fonte: PDF]

Protezione dei minori — art. 28 [fonte: PDF]

Divieti assoluti: - Divieto di pubblicità basata su profilazione ai minori - Divieto di interfacce progettate per sfruttare le debolezze dei minori (dark pattern aggressivi)

Obblighi per le VLOP: - Valutazione specifica dei rischi per i minori nella valutazione annuale dei rischi sistemici - Misure di attenuazione specifiche (parental control, impostazioni di default più sicure)

Il DSA non richiede verifica dell'età obbligatoria, ma i fornitori che rivolgono servizi ai minori devono prendere misure adeguate. [fonte: PDF]

Cosa sono «misure adeguate» senza verifica dell'età?

Senza verifica formale (documento d'identità), le piattaforme adottano misure indirette:

- **Impostazioni di default più restrittive:** profili di nuovi utenti visibili solo agli amici; messaggi da sconosciuti disabilitati di default - **Parental control:** strumenti per i genitori per impostare limiti di utilizzo e filtrare contenuti - **Limitazioni algoritmiche:** non mostrare contenuti per adulti su account che dichiarano un'età minore - **Limitazioni sulla pubblicità:** nessuna pubblicità comportamentale rivolta agli under 18 - **Età dichiarata come proxy:** se l'utente dichiara di essere minorenne in fase di registrazione, riceve un'esperienza più protetta; se mente, la responsabilità si sposta sull'utente

Non c'è obbligo di verifica formale perché sarebbe sproporzionato e invasivo per la privacy; ma la piattaforma deve documentare le misure adottate.

Obblighi per VLOP e VLOSE [fonte: PDF]

- **Valutazione annuale dei rischi sistemici** (art. 34): rischi derivanti dal funzionamento e dall'uso del servizio — contenuti illegali, effetti su diritti fondamentali, disinformazione, violenza di genere, salute pubblica
- **Misure di attenuazione dei rischi** (art. 35): adattamento dei sistemi di raccomandazione, moderazione, cooperazione con le autorità

- **Audit indipendenti** (art. 37): audit annuali sulla conformità, condotti da revisori esterni accreditati

Cosa sono gli audit indipendenti?

Un audit è un processo di verifica condotto da un soggetto esterno. Per le VLOP e VLOSE il DSA richiede che ogni anno un revisore esterno **accreditato** (non un dipendente della piattaforma, non un soggetto scelto liberamente da essa) verifichi: - Se la piattaforma ha effettivamente condotto la valutazione dei rischi sistemici - Se le misure di attenuazione adottate sono adeguate - Se rispetta gli obblighi di trasparenza sugli algoritmi - Se mantiene correttamente il repository degli annunci

Il rapporto di audit viene trasmesso alla Commissione europea. Serve a evitare l'autoregolazione: le piattaforme non possono semplicemente dichiarare di essere conformi — devono farlo verificare da un soggetto terzo. È la stessa logica dei bilanci certificati da revisori contabili nelle società quotate. [fonte: PDF]

- **Accesso ai dati ai ricercatori** (art. 40): condivisione con ricercatori accademici accreditati per analizzare i rischi sistemici
- **Responsabile della conformità** (art. 41): nomina di uno o più responsabili interni indipendenti con competenze specifiche
- **Trasparenza degli algoritmi di raccomandazione** (art. 38): consentire agli utenti di optare per un sistema non basato sulla profilazione
- **Repository degli annunci pubblicitari** (art. 39): archivi pubblici di tutti gli annunci mostrati, per almeno un anno

VLOP designate (dal 2023): Facebook, Instagram, TikTok, Twitter/X, LinkedIn, YouTube, Snapchat, Pinterest, Amazon Store, Booking.com, Apple App Store, Google Play, Zalando, Wikipedia, AliExpress. VLOSE: Bing, Google Search. [fonte: PDF]

Sistema sanzionatorio DSA [fonte: PDF]

Violazione	Sanzione
Violazione degli obblighi del Regolamento	Fino al 6% del fatturato mondiale annuo
Informazioni inesatte, incomplete o fuorvianti	Fino all' 1% del fatturato mondiale annuo
Penalità di mora	Fino al 5% del fatturato medio giornaliero mondiale

In caso di inadempienza sistematica: misure comportamentali o strutturali; per violazioni gravi e reiterate che minaccino la vita o la sicurezza: limitazione temporanea dell'accesso alla piattaforma per specifici destinatari. [fonte: PDF]

PARTE II — Digital Markets Act (DMA)

Obiettivo: garantire mercati digitali equi e contendibili, impedendo che pochi operatori controllino gli accessi essenziali a danno di concorrenti e consumatori. [fonte: PDF]

Logica ex ante (preventiva): a differenza del diritto antitrust tradizionale, il DMA non aspetta che si verifichi un danno concorrenziale — impone obblighi e divieti precauzionali a chi controlla snodi essenziali del mercato digitale. [fonte: PDF]

Il diritto antitrust tradizionale interviene **ex post** (dopo aver accertato l'abuso e dimostrato la posizione dominante caso per caso); il DMA interviene **ex ante** (prima che il danno avvenga), imponendo obblighi precauzionali strutturali.

Il concetto di gatekeeper [fonte: PDF]

Gatekeeper: un'impresa che gestisce uno o più «servizi di piattaforma di base» (CPS) e soddisfa i seguenti **criteri cumulativi** (art. 3):

1. **Impatto significativo nel mercato interno:** fatturato annuo ≥ 7,5 mld € nell'UE negli ultimi 3 esercizi, OPPURE capitalizzazione di mercato ≥ 75 mld €; servizio in ≥ 3 Stati membri
2. **Ruolo di gateway:** ≥ 45 milioni di utenti attivi mensili nell'UE e ≥ 10.000 utenti commerciali attivi annui
3. **Posizione consolidata e duratura:** la posizione è o sarà stabilmente consolidata (anche soggetti «emergenti» possono essere designati)

Gatekeeper designati (2023-2024): Alphabet, Amazon, Apple, Booking, ByteDance, Meta, Microsoft → 23 CPS complessivamente designati. [fonte: PDF]

Distinzione critica: VLOP (DSA) vs gatekeeper (DMA)

	VLOP (DSA)	Gatekeeper (DMA)
Criterio	Un solo criterio: ≥ 45 mln utenti UE	Tre criteri cumulativi
Fatturato	Non rilevante	≥ 7,5 mld € O capitalizzazione ≥ 75 mld €
Utenti	≥ 45 mln utenti mensili UE	≥ 45 mln utenti mensili + ≥ 10K utenti commerciali
Autorità	Commissione (VLOP) + DSC nazionale	Commissione (competenza esclusiva)

Una piattaforma con 50 mln di utenti UE ma piccolo fatturato → è VLOP (DSA), NON gatekeeper (DMA). Meta è contemporaneamente VLOP (molti utenti → DSA) e gatekeeper (molti utenti + fatturato enorme → DMA), ma per ragioni diverse, con obblighi diversi. [fonte: PDF]

Servizi di piattaforma di base (CPS) [fonte: PDF]

Il DMA si applica alle piattaforme che forniscono: marketplace, motori di ricerca, sistemi operativi, browser, cloud computing, messaggistica numero-indipendente (WhatsApp, iMessage), piattaforme video, social network, servizi pubblicitari collegati a un CPS gatekeeper, assistenti virtuali.

Obblighi dei gatekeeper — «do's» [fonte: PDF]

Interoperabilità: garantire che le funzioni base dei servizi di messaggistica (es. WhatsApp) siano interoperabili con servizi di terzi che ne facciano richiesta.

Ma in cosa è interoperabile WhatsApp?

Il DMA impone a Meta di aprire le API di WhatsApp a servizi di messaggistica di terzi — permettere a un utente di Signal o Telegram di **mandare e ricevere messaggi con utenti WhatsApp** senza avere un account WhatsApp.

In pratica: puoi mandare un messaggio a un contatto su WhatsApp usando Signal (se Signal ha fatto richiesta e Meta ha implementato l'interoperabilità). I messaggi fluiscono tra le app come le email tra provider diversi — Gmail Outlook Yahoo usano lo stesso protocollo SMTP e si «capiscono».

Le «funzioni base» da interoperare sono: messaggi di testo 1:1, messaggi di gruppo, condivisione di file — quelle essenziali, non necessariamente tutte le feature avanzate. La crittografia end-to-end deve essere mantenuta compatibilmente con l'interoperabilità (tema tecnico ancora in discussione implementativa). [fonte: PDF]

Portabilità dei dati: consentire agli utenti finali e commerciali di portare i propri dati a servizi concorrenti, in tempo reale e gratuitamente.

Tipo passaggio Apple → Android dei dati? Esattamente. La portabilità DMA va oltre: non solo foto e contatti, ma anche cronologia acquisti, preferenze, impostazioni — in formato leggibile da altri sistemi, così che passare da un gatekeeper a un concorrente non comporti perdere tutto ciò che hai accumulato.

Accesso ai dati di performance: fornire agli inserzionisti e agli editori l'accesso ai dati sulle loro campagne e sulle performance sulla piattaforma.

Notifica acquisizioni: informare la Commissione di tutte le acquisizioni e fusioni realizzate.

“Ma che Commissione?” La Commissione europea — l'organo esecutivo dell'UE. Il DMA le assegna competenza esclusiva: nessuna autorità nazionale concorrente per i gatekeeper, è sempre la Commissione europea a decidere.

Trasparenza degli algoritmi di ranking: fornire informazioni chiare sui criteri di posizionamento per gli utenti commerciali.

Accesso alle app store: consentire agli sviluppatori di accedere alle stesse API e funzionalità disponibili al gatekeeper.

In parole povere?

Immagina di sviluppare un'app per iOS. Il chip NFC dell'iPhone (usato per i pagamenti contactless) era accessibile solo ad Apple Pay — non a Google Pay, PayPal, o altre app di terzi. Questo avvantaggiava Apple nel mercato dei pagamenti digitali.

Il DMA impone che Apple dia agli sviluppatori di terzi **accesso alle stesse API** che usa per le proprie app. Se Apple può usare NFC per Apple Pay, anche un'app di pagamento concorrente deve poterlo fare.

In sintesi: niente «funzionalità esclusive» che il gatekeeper tiene per sé mentre le nega ai concorrenti che operano sulla sua piattaforma.

Divieti per i gatekeeper — «don'ts» [fonte: PDF]

Self-preferencing: vietato classificare i propri prodotti/servizi in modo più favorevole rispetto a quelli di terzi (es. Google Shopping nei risultati di Google Search).

Anti-steering: vietato impedire agli utenti commerciali di informare i propri clienti di offerte più convenienti fuori dalla piattaforma.

Cosa implica nel pratico?

Su App Store di Apple, un'app di streaming (es. Spotify) non poteva inserire all'interno dell'app un link alla propria pagina web con l'abbonamento diretto — che costava meno perché non includeva la commissione del 30% di Apple. Apple vietava di «indirizzare» (to steer) gli utenti fuori dalla piattaforma.

Il DMA vieta questa pratica: lo sviluppatore deve poter dire ai propri utenti «abbonati sul nostro sito, è più economico» e inserire un link diretto. Apple non può impedirlo. [fonte: PDF]

Bundling forzato: vietato obbligare gli utenti a installare o usare servizi del gatekeeper come condizione per accedere ad altri (es. preinstallazione obbligatoria non rimovibile).

Tracciamento senza consenso: vietato combinare dati personali provenienti da diversi CPS o da siti terzi ai fini di pubblicità mirata, salvo consenso effettivo dell'utente.

In parole povere?

Meta gestisce Facebook, Instagram, WhatsApp e Messenger (quattro CPS diversi). Senza questo divieto, potrebbe incrociare automaticamente i tuoi comportamenti su tutti e quattro per costruire un profilo pubblicitario ultra-preciso — vedi un video di certe scarpe su Facebook e ti appaiono su Instagram anche se non hai mai cercato nulla su Instagram.

Il DMA dice: se vuoi combinare i miei dati da Facebook con quelli da Instagram per mostrarmi pubblicità mirata, devi chiedermi il **consenso effettivo**, genuino, informato — non il solito banner cookie con il tasto «rifiuta» nascosto. [fonte: PDF]

Connessione con D8 (GDPR): questo divieto rispecchia il principio di consenso del GDPR. In caso di conflitto tra DMA e GDPR, prevale il GDPR.

Piattaforme di pagamento: vietato impedire agli sviluppatori di usare piattaforme di pagamento di terzi per la vendita di app.

Tipo? Apple imponeva che tutti gli acquisti in-app sulle app iOS passassero dal sistema di pagamento di Apple (commissione del 15-30%). Un'app non poteva integrarsi con Stripe, PayPal o altri processori. Il DMA vieta questa esclusiva: gli sviluppatori possono usare sistemi di pagamento alternativi.

Lock-in: vietato ostacolare la disinstallazione di software/app preinstallate.

Esempio? Su Android, alcune app Google (Maps, Chrome, Gmail) erano preinstallate e non disinstallabili — solo «disabilitabili». Il DMA vieta che il gatekeeper impedisca la disinstallazione delle proprie app preinstallate: l'utente deve poter rimuoverle liberamente se vuole usare alternative.

Designazione e procedura [fonte: PDF]

- Il fornitore che raggiunge le soglie quantitative deve **notificare alla Commissione entro 2 mesi**
- La Commissione emette la decisione di designazione entro **45 giorni lavorativi** dalla notifica completa
- Dopo la designazione, il gatekeeper ha **6 mesi** per conformarsi agli obblighi del DMA
- **Riesame periodico**: almeno ogni 3 anni dello status di gatekeeper
- **Vigilanza**: la Commissione europea ha competenza esclusiva sull'applicazione del DMA

Imprecisione da correggere: questa sezione descrive la PROCEDURA, non le condizioni

Lorenzo ha chiesto: «quindi queste sono le condizioni per essere designati gatekeeper?»

No. Questa sezione descrive la **procedura** (chi notifica, entro quanto, tempi della decisione, quando scattano gli obblighi). Le **condizioni** per essere designati sono i **3 criteri cumulativi** della sezione precedente: impatto significativo + ruolo di gateway + posizione consolidata.

Schema: **criteri soddisfatti** → obbligo di notifica alla Commissione → **procedura** (45 gg per la decisione) → **designazione** → 6 mesi per conformarsi agli obblighi.

Analogia: le condizioni per la patente sono superare l'esame teorico e pratico. La procedura è presentare domanda, sostenere gli esami, ricevere il documento. Non vanno confuse.

Sistema sanzionatorio DMA [fonte: PDF]

Violazione	Sanzione
Violazione di obblighi o divieti	Fino al 10% del fatturato totale mondiale dell'anno precedente
Violazione ripetuta (recidiva)	Fino al 20% del fatturato totale mondiale
Penalità di mora	Fino al 5% del fatturato medio giornaliero mondiale

Misure strutturali in caso di inosservanza sistematica: se il gatekeeper viola gli obblighi per 3 volte in 8 anni, la Commissione può imporre rimedi comportamentali e strutturali — come ultima risorsa: obbligo di vendere una (parte della) propria attività o divieto di acquisire nuovi servizi. [fonte: PDF]

Casi pratici [fonte: PDF]

Apple e il mercato delle app (marzo 2024): indagini formali per anti-steering nell'App Store, browser choice screen non conforme al DMA, accesso insufficiente alle funzioni NFC da parte di app di terzi. Primo caso DMA contro un gatekeeper; dimostra la portata dell'approccio ex ante.

Google Shopping e self-preferencing (2017, pre-DMA): multato di 2,42 mld € per aver favorito Google Shopping nei risultati di ricerca. Con il DMA, il self-preferencing è ora vietato ex ante per tutti i gatekeeper: non è più necessario dimostrare la posizione dominante caso per caso.

PARTE III — Data Act

Obiettivo: rendere i dati generati da prodotti connessi (IoT) e servizi correlati più accessibili e circolanti, per creare un vero mercato unico europeo dei dati equo e interoperabile. [fonte: PDF]

“In che senso mercato dei dati, in che senso prodotti connessi, a chi si rivolge?”

Partiamo dal problema concreto.

Compri un'auto connessa. Mentre guidi, l'auto raccoglie migliaia di dati: velocità, consumo, stile di guida, diagnostici del motore, posizione GPS. Questi dati vengono trasmessi al produttore (es. BMW). L'officina indipendente non può accedervi — sono disponibili solo al dealer ufficiale BMW, con strumenti certificati a costi elevati. Sei vincolato al dealer ufficiale perché solo loro hanno i dati del tuo veicolo.

Mercato dei dati: dati che oggi sono intrappolati dal produttore potrebbero circolare — l'officina può accedervi; le assicurazioni possono calcolare premi personalizzati; i ricercatori possono analizzare pattern di traffico. È un «mercato» nel senso di circolazione economica basata sui dati.

Prodotti connessi: qualsiasi oggetto fisico che raccoglie e trasmette dati — auto, smartwatch, macchinari industriali, contatori smart, elettrodomestici connessi, dispositivi medici.

A chi si rivolge: ai produttori di questi oggetti (obbligo di rendere i dati accessibili agli utenti), ai fornitori di servizi cloud (obbligo di facilitare il passaggio a concorrenti), agli utenti (diritto di accedere ai propri dati e condividerli). [fonte: PDF]

Il Data Act si inserisce nella **strategia europea dei dati**, accanto a: GDPR (dati personali), Data Governance Act (condivisione volontaria), DMA (portabilità sulle piattaforme gatekeeper). [fonte: PDF]

Ambito di applicazione [fonte: PDF]

Si applica a (art. 1): - **Produttori di prodotti connessi** immessi sul mercato UE e loro fornitori di servizi correlati - **Titolari dei dati che mettono a disposizione dati** ai destinatari nell'UE

“In che senso titolari dei dati che mettono a disposizione dati ai destinatari?”

Il «titolare dei dati» è chi ha il diritto/obbligo di mettere a disposizione quei dati — tipicamente il produttore o il fornitore di servizi. La formula «mettono a disposizione dati ai destinatari» descrive l'obbligo principale del Data Act: il titolare deve aprire l'accesso a chi ne ha diritto (utente, terzi designati dall'utente, enti pubblici in emergenza). Non si tratta di «vendere dati» — significa che quel soggetto è il custode dei dati e ha l'obbligo di renderli accessibili.

- **Destinatari dei dati** nell'UE
- **Fornitori di servizi di trattamento dei dati** (cloud, edge) ai clienti nell'UE
- **Enti pubblici degli Stati membri e istituzioni UE** che richiedono dati ai titolari in situazioni eccezionali

“**Chi?**” (gli enti pubblici) Enti pubblici nazionali (protezione civile, sanità pubblica, autorità di gestione delle crisi) E la Commissione europea (per emergenze o crisi a livello UE). Il soggetto richiedente deve avere una base legale esplicita per la richiesta.

Definizioni chiave: [fonte: PDF] - **Prodotto connesso:** oggetto che raccoglie e trasmette dati (auto connessa, smartwatch, macchinario industriale, contatore smart, elettrodomestico connesso) - **Utente:** chi possiede/noleggia/usa il prodotto connesso (consumatore o impresa) - **Titolare dei dati:** chi ha il diritto/obbligo di utilizzare e mettere a disposizione i dati (es. il produttore)

Imprecisione da correggere: titolare dei dati utente nel Data Act

Lorenzo: «Non mi è chiaro, avrei detto che l'utente è titolare dei suoi dati»

Intuizione comprensibile, ma nel Data Act la terminologia è precisa e diversa dal GDPR.

Nel GDPR: «titolare del trattamento» = chi decide come trattare i dati. Nel Data Act: «titolare dei dati» (data holder) = chi ha il diritto/obbligo di mettere a disposizione i dati — tipicamente il produttore, che li raccoglie fisicamente.

L'utente non è «titolare» nel senso del Data Act: è il **beneficiario dei diritti di accesso**. Ha il diritto di richiedere i dati, ma non è il soggetto che li detiene e li mette a disposizione.

Paralelo: nella tua banca, la banca «possiede» il database delle transazioni. Tu hai il diritto di accedere ai tuoi movimenti e di portarli altrove (portabilità). Ma la banca è il «titolare» che mette a disposizione, non tu. [fonte: PDF]

Diritto di accesso ai dati da prodotti connessi [fonte: PDF]

Diritto di accesso dell'utente:

L'utente di un prodotto connesso ha il diritto di accedere, in modo **gratuito**, sicuro e — ove tecnicamente possibile — in **tempo reale**, ai dati generati dall'uso del prodotto connesso. I dati devono essere in formato **strutturato, di uso comune e leggibile da dispositivo automatico** (machine-readable). [fonte: PDF]

“Machine-readable — ad esempio la memoria di un LLM sempre leggibile e modificabile?”

«Machine-readable» significa che il formato è strutturato in modo che un programma possa leggerlo e processarlo automaticamente — senza che un essere umano debba interpretarlo visivamente.

Esempi di formato machine-readable: JSON, CSV, XML — file strutturati dove un programma sa dove trovare ogni campo. Esempi di formato NON machine-readable: un PDF scannerizzato, una foto, un documento Word non strutturato.

La memoria di un LLM (i pesi del modello) è tutt'altra cosa — sono miliardi di parametri numerici, non «dati dell'utente generati da un prodotto connesso». I dati del Data Act sono dati operativi d'uso del prodotto: velocità dell'auto, battito cardiaco dallo smartwatch, consumo del contatore. Devono essere esportabili in formato machine-readable; il diritto è di **accesso e portabilità**, non di modifica dei dati grezzi. [fonte: PDF]

Obblighi del produttore: [fonte: PDF] - Informare precontrattualmente l'utente: tipo, formato, volume dei dati generati; se e come sono accessibili al produttore - **Progettazione by default**

(art. 4 §1): i prodotti devono essere progettati per permettere l'accesso predefinito dell'utente ai propri dati — obbligo dal 12 settembre 2026 - I dati non possono essere usati per trarre conclusioni su posizione economica, salute, preferenze dell'utente **senza consenso**

Condivisione dati con terzi [fonte: PDF]

Diritto dell'utente di condividere dati con terzi:

Su richiesta dell'utente, il titolare dei dati deve condividere i dati con **terzi designati dall'utente**, a condizioni **FRAND** (eque, ragionevoli e non discriminatorie). I terzi che ricevono i dati possono usarli solo per le **finalità concordate con l'utente**. [fonte: PDF]

“Voglio un esempio pratico di questa situazione”

Hai uno smartwatch che raccoglie dati di salute (frequenza cardiaca, ore di sonno, attività fisica). Il produttore (es. Garmin) è il titolare dei dati.

Senza Data Act: Garmin condivide i tuoi dati solo con le app che ha approvato (o li tiene per sé per analisi commerciali).

Con Data Act: tu dici a Garmin «voglio che i miei dati di frequenza cardiaca siano accessibili alla mia app di medicina dello sport preferita» (terzo da te designato). Garmin deve fornire quei dati a quella app, a condizioni FRAND — non può chiedere un prezzo sproporzionato.

L'app di terzi può usare i dati **solo per le finalità concordate con te** — non può rivenderli ad altri o usarli per pubblicità. [fonte: PDF]

Condivisione dati B2B obbligatoria (cap. III): [fonte: PDF]

Obbligo di condivisione tra imprese a condizioni FRAND, qualora previsto da atti legislativi UE o nazionali. Compensazione equa: il titolare può richiedere compensazione (valutata come costo marginale). Tutela segreti commerciali: il titolare può rifiutare se la condivisione rivelerebbe segreti commerciali non adeguatamente tutelabili.

“Non riesco a immaginarmi un commercio di dati B2B”

Scenario concreto: un macchinario industriale in una fabbrica raccoglie dati di performance (temperature, vibrazioni, cicli di produzione). Il produttore del macchinario (es. Siemens) ha accesso a quei dati. Il cliente industriale (es. Fiat) vuole quei dati per:

- Ottimizzare la manutenzione predittiva (intervenire prima della rottura, non dopo)
- Condividerli con il proprio fornitore di manutenzione indipendente - Confrontare le performance con altri macchinari simili

Senza Data Act: Siemens potrebbe tenere i dati per sé e vendere contratti di assistenza esclusivi (vendor lock-in). Con Data Act: Fiat ha il diritto di accedere ai dati del proprio macchinario e di condividerli B2B con chi vuole, a condizioni FRAND.

Il «commercio di dati B2B» è la circolazione di dati tra imprese lungo una filiera produttiva o di manutenzione — non necessariamente una vendita in denaro, ma uno scambio che crea valore economico. [fonte: PDF]

Clausole contrattuali abusive e protezione delle PMI [fonte: PDF]

Una clausola contrattuale tra imprese è **abusiva** se: - Esclude o limita in modo eccessivo **la responsabilità** della parte che impone la clausola per danni causati dall'inadempimento del contratto - Esclude i mezzi di ricorso della parte che riceve i dati se non vengono rispettati i requisiti relativi alla qualità dei dati - Concede alla parte che impone la clausola il diritto di modificare **unilateralmente** le condizioni del contratto

“Non ho capito verso chi” (la responsabilità)

La clausola abusiva esclude la responsabilità **della parte forte (chi impone la clausola)** verso **la parte debole (chi riceve i dati, tipicamente la PMI)**.

Esempio: un grande produttore di macchinari impone a una PMI un contratto che dice «in caso di dati di qualità scadente o ritardo nella messa a disposizione, il produttore non è responsabile di alcun danno». La PMI non può fare nulla se i dati arrivano sbagliati o in ritardo — la clausola scarica tutti i rischi su di lei.

Il Data Act protegge le PMI dalle clausole squilibrate imposte da partner più grandi (fornitori di piattaforme dati, produttori di macchinari, cloud provider). [fonte: PDF]

Accesso dei soggetti pubblici ai dati privati [fonte: PDF]

Gli enti pubblici (e la Commissione) possono richiedere ai titolari privati dati necessari per: - Risposta a **emergenze pubbliche** (calamità naturali, pandemie, grandi incidenti) - Prevenzione o ripristino in caso di **crisi eccezionale** (black-out, interruzione di infrastrutture critiche) - Svolgimento di un **compito di interesse pubblico** esplicitamente previsto dalla legge

Condizioni e garanzie: [fonte: PDF] - La richiesta deve essere necessaria, proporzionata e motivata; il titolare non può rifiutare senza giustificazione; i dati non possono essere usati per usi commerciali o condivisi senza consenso - Il titolare dei dati riceve **compensazione equa** (valutata come costo di messa a disposizione) - I dati devono essere **cancellati** una volta esaurito lo scopo della richiesta

Questa sezione (condizioni e garanzie) non era negli appunti grezzi — inclusa perché costituisce un dettaglio rilevante per l'esame.

Portabilità e switching tra servizi cloud [fonte: PDF]

Obiettivo: eliminare il **vendor lock-in** nei servizi cloud (IaaS, PaaS, SaaS).

Obblighi dei fornitori di cloud: - Eliminare barriere tecniche, contrattuali e commerciali che rendono difficile il passaggio a un concorrente - Garantire **equivalenza funzionale** durante la migrazione dei dati e delle risorse digitali - Consentire la **disaggregazione dei servizi** (ove tecnicamente fattibile) - **Abolizione graduale delle switching fees:** da settembre 2025 riduzione; dal 12 settembre 2027 gratuite

“Fornisci esempi tangibili per questi obblighi”

Barriere tecniche da eliminare: AWS usa formati proprietari per i backup dei database. Se vuoi migrare su Google Cloud, devi convertire tutto. Il Data Act impone di supportare formati standard interoperabili che non leghino i dati al provider.

Equivalenza funzionale durante la migrazione: se la tua applicazione su Azure usa un servizio di messaggistica interna (Azure Service Bus), durante la migrazione a AWS i messaggi non devono andare persi e il servizio deve funzionare equivalentemente. Non puoi imporre un downtime di 3 giorni per fare la migrazione.

Disaggregazione: oggi con Google Workspace è difficile migrare solo la posta elettronica senza portarsi anche Docs, Drive, Calendar — tutto è intrecciato. La disaggregazione obbliga a permettere di migrare singoli servizi separatamente.

Switching fees gratuite dal 2027: oggi AWS fa pagare per l'uscita dei dati (egress fee): scarichi 10 TB dai loro server per portarli altrove, paghi per ogni GB. Dal 12 settembre 2027 questa fee sarà gratuita per chi migra verso un altro fornitore. [fonte: PDF]

Interoperabilità: i fornitori di servizi di trattamento dati devono adottare standard tecnici per garantire l'interoperabilità. La Commissione può specificare standard armonizzati obbligatori tramite atti di esecuzione. [fonte: PDF]

Trasferimento internazionale di dati non personali [fonte: PDF]

I fornitori di servizi cloud che trattano dati non personali nell'UE devono adottare misure per impedire l'accesso non autorizzato da parte di autorità di paesi terzi.

Se un'autorità di un paese terzo ordina il trasferimento di dati non personali, il fornitore deve: - Informare il cliente prima di trasferire i dati (salvo divieto legale) - Contestare l'ordine se viola il diritto UE o di uno Stato membro - Non trasferire se l'ordine è manifestamente contrario all'ordine pubblico dell'UE

“Come mai solo dati non personali? E per i dati personali? E poi li proteggono dalle autorità — non sono i ‘buoni’?”

Perché solo i dati non personali: per i dati personali esiste già il GDPR, che disciplina esaustivamente i trasferimenti internazionali (adeguatezza, clausole standard, ecc.). Il Data Act non vuole duplicare il GDPR — interviene dove c'è un vuoto, cioè sui dati non personali: dati industriali, dati aggregati anonimi, dati delle macchine.

Per i dati personali: rimane pienamente applicabile il GDPR. Se un'autorità USA vuole i dati personali degli europei da un cloud provider, la questione è regolata dal GDPR e dagli accordi UE-USA (Data Privacy Framework) — non dal Data Act. [fonte: PDF]

“Non sono i ‘buoni’?” Le autorità UE sono i «buoni» — ti proteggono e applicano i tuoi diritti. Il problema qui sono le **autorità di paesi terzi** (es. autorità USA, cinesi) che possono ordinare a un cloud provider americano (es. AWS) di consegnare dati memorizzati in Europa, senza che l'utente europeo lo sappia. Il conflitto è tra la legge americana (che può imporre ad AWS di consegnare dati ovunque si trovino) e la legge europea (che protegge quei dati). Il Data Act rafforza la protezione: il provider deve resistere all'ordine se contrasta col diritto UE, e informare il cliente se non può resistere.

Governance e sanzioni Data Act [fonte: PDF]

- Ogni Stato membro designa un'autorità competente (può coincidere con il Garante privacy)

- Coordinamento tramite **Comitato europeo per i dati (EDIB)**
- Il Regolamento **non fissa un massimale comune**: richiede sanzioni «efficaci, proporzionate e dissuasive» — ogni Stato membro definisce le proprie
- **Rapporto con GDPR**: in caso di conflitto tra Data Act e GDPR, **prevalgono le norme GDPR** (art. 1 §5) [fonte: PDF]

Caso pratico — auto connessa: Un automobilista acquista un veicolo connesso. Il produttore raccoglie dati (velocità, consumo, posizione, diagnostici). L'officina indipendente non può accedervi — solo il dealer ufficiale, con strumenti costosi. Con il Data Act: l'automobilista ha il diritto di richiedere i dati in formato machine-readable e condividerli con l'officina di fiducia; il produttore non può usare i dati per svantaggiare l'utente. Stesso principio per macchinari industriali, elettrodomestici smart, dispositivi medici connessi, contatori smart. [fonte: PDF]

Quadro d'insieme e coordinamento con GDPR

	DSA	DMA	Data Act
Chi regola	Intermediari online	Gatekeeper (grandi piattaforme)	Produttori prodotti connessi + cloud
Cosa regola	Contenuti, responsabilità, moderazione	Struttura dei mercati digitali	Accesso e circolazione dei dati IoT
Autorità di vigilanza	Commissione (VLOP/VLOSE) + DSC nazionale	Commissione (competenza esclusiva)	Autorità nazionale designata + EDIB
Sanzione massima	6% fatturato mondiale	10% / 20% in caso di recidiva	Sanzioni nazionali «efficaci»

Coordinamento con GDPR: [fonte: PDF] - Data Act vs GDPR: in caso di conflitto, prevalgono le norme GDPR - DSA: il divieto di pubblicità su categorie speciali di dati si sovrappone all'art. 9 GDPR - DMA: il divieto di tracciamento senza consenso rispecchia il principio di consenso del GDPR

In comune per tutti e tre: applicazione extraterritoriale, coordinamento con il GDPR, Commissione europea con ampi poteri di vigilanza. [fonte: PDF]

Riepilogo

DSA: il principio cardine è «ciò che è illegale offline è illegale online». Regola gli intermediari con obblighi proporzionati alla loro dimensione (dalla meno obbligata mere conduit alla più obbligata VLOP/VLOSE), mantiene il safe harbour, vieta i dark pattern e la pubblicità profilata ai minori, impone trasparenza sugli algoritmi di raccomandazione. Sanzione: fino al 6% del fatturato mondiale.

DMA: la logica è ex ante e preventiva. Il gatekeeper è designato dalla Commissione quando soddisfa tre criteri cumulativi (impatto significativo, ruolo di gateway, posizione consolidata). Ha obblighi strutturali (portabilità, interoperabilità) e divieti assoluti (self-preferencing, anti-steering, bundling)

forzato, tracciamento senza consenso). Sanzioni: fino al 10% del fatturato mondiale, 20% in caso di recidiva.

Data Act: il principio fondante è che i dati generati dall'uso di un prodotto connesso appartengono — in termini di accesso — all'utente, non al produttore. Il produttore deve consentire l'accesso gratuito e in tempo reale, in formato machine-readable; il passaggio tra fornitori cloud non deve comportare vendor lock-in; le switching fees saranno gratuite dal 12 settembre 2027.

Autoverifica (5 domande) disponibile in `lezione_moduloD13_pacchetto_digitale.md` — da completare per portare il modulo a .